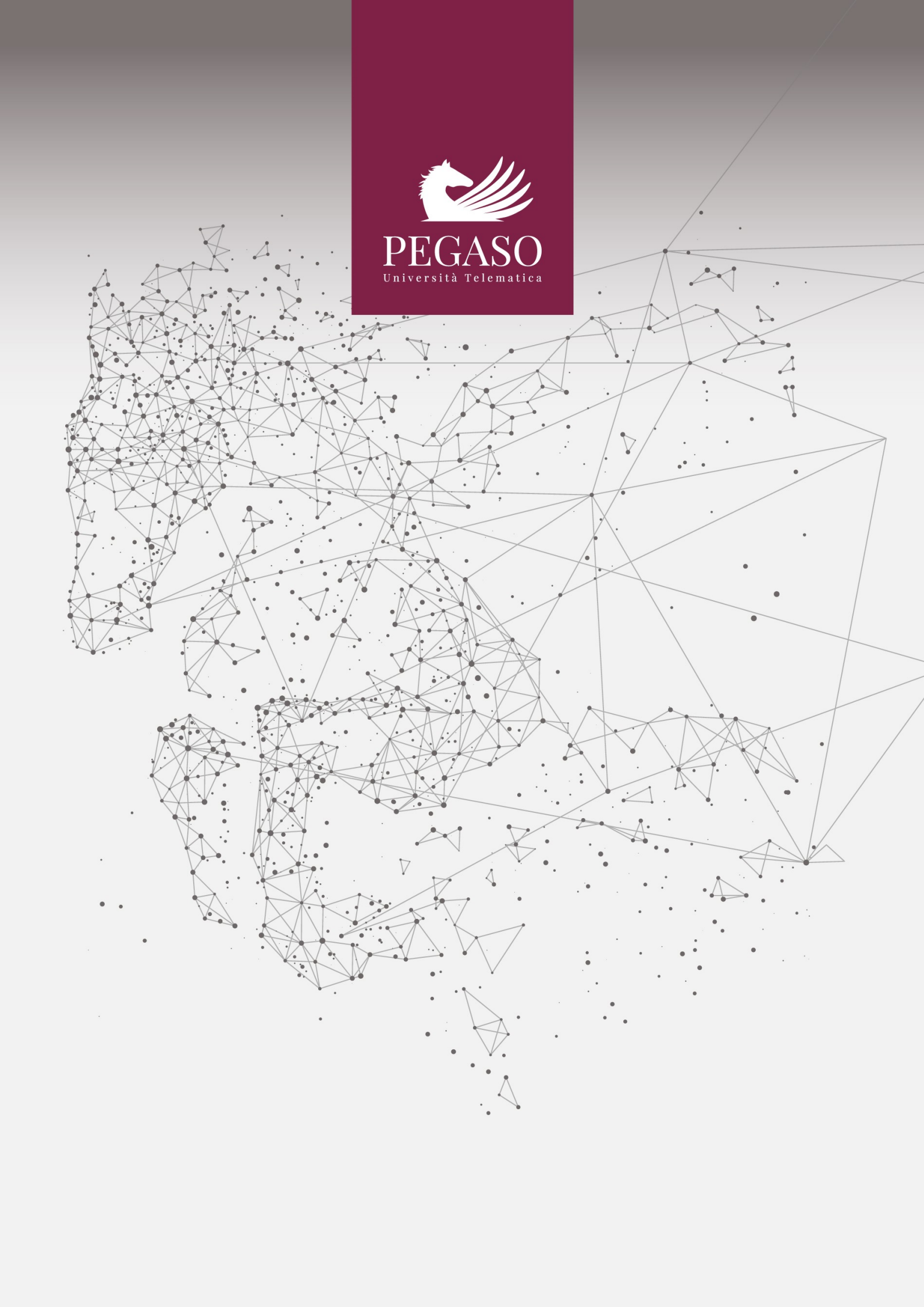

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1. COMUNICAZIONI ANONIME 3
2. IL PROTOCOLLO CROWDS 7
3. IL PROTOCOLLO MIX 11
SITOGRAFIA 15

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1. Comunicazioni anonime

Il concetto che sta alla base delle *comunicazioni anonime* è che le identità dei soggetti coinvolti siano nascoste:

- *reciprocamente*
- *a terze parti*

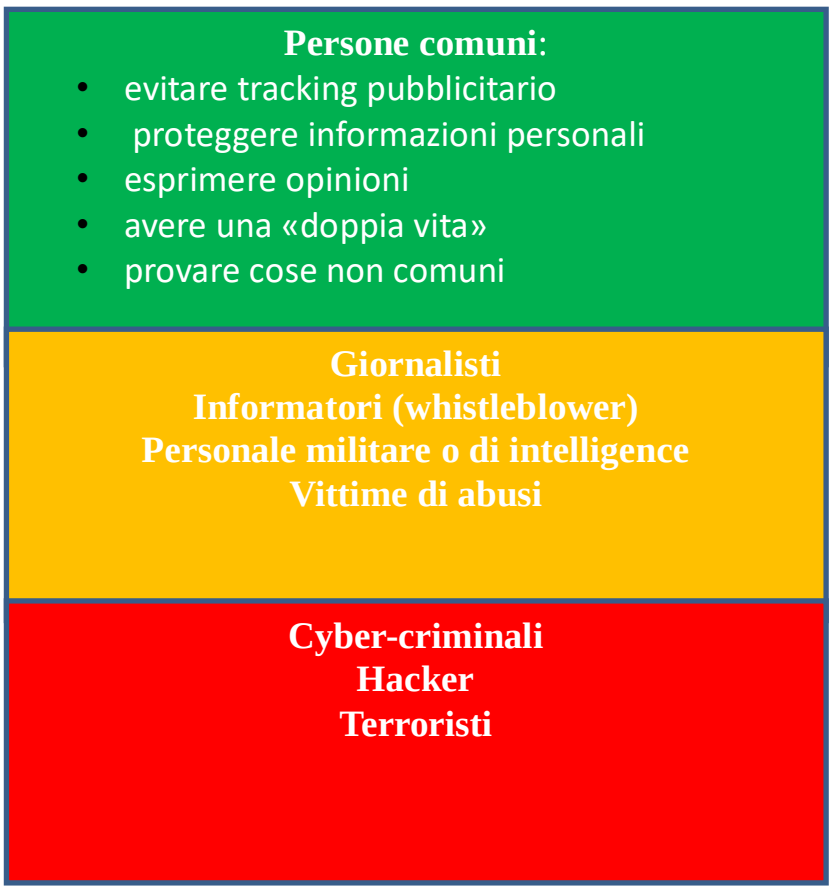
In particolare, ciò che un utente generalmente vuole proteggere è:

- La propria identità nei confronti del soggetto con cui sta interagendo
- L'identità del soggetto con cui sta interagendo dalla vista di terze parti

La necessità di operare/comunicare in anonimato nasce in relazione a varie esigenze operative che possono essere più o meno legittime. Nella figura di seguito sono presentati alcuni esempi di soggetti e comportamenti che possono necessitare di una comunicazione anonima; gli esempi sono presentati in figura in ordine crescente di illegittimità. Partendo dalle esigenze delle "persone comuni" che possono voler tenere nascosti i propri dati personali o le proprie attività, si passa a "giornalisti", "informatori" e/o persone che intendono comunicare ma non lo possono fare liberamente, fino ad arrivare ai "cyber-criminali" e persino i "terroristi".

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



Nonostante tutto, restare anonimi è molto difficile, esistono vari strumenti per il tracciamento dei dati e delle azioni:

- L'indirizzo IP può essere collegato direttamente ad utente

gli ISP memorizzano le comunicazioni per molti anni

le forze dell'ordine possono accedere a tali dati

- Le applicazioni usate sono tracciate

Cookies, e-tags, HTML5 storage

Servizi centralizzati: Google, Skype, Whatsapp

Browser fingerprinting: i siti web memorizzano informazioni sul tipo, la versione, il sistema operativo, la lingua, ecc.

- Le attività possono essere tracciate: siti web, link, apps.

Prima di proseguire facciamo alcune precisazioni:

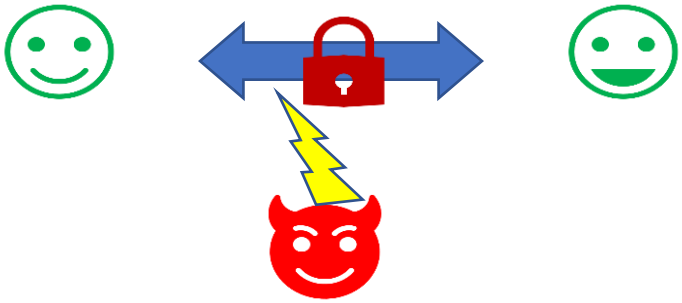
PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- esistono due tipi di anonimato, quello fra mittente/ricevente e quello relativo alla comunicazione fra mittente e ricevente
- *Unlinkability*: con tale termine si intende l'impossibilità di collegare due o più oggetti di interesse per rompere l'anonimato come eventi, persone, azioni
- *Unobservability*: con tale termine si intendono oggetti di interesse che sono indistinguibili da tutti gli altri

Vediamo adesso alcuni sistemi per l'anonimato e cosa si riesce effettivamente a proteggere.

Nel caso di *comunicazione cifrata* si capisce bene che la *crittografia* non basta:

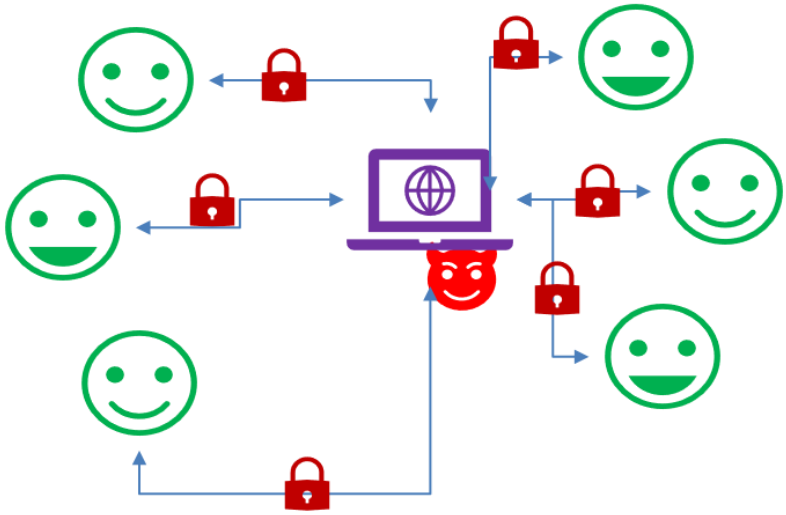


Come simbolicamente evidenziato in figura qui sopra, la comunicazione in questo caso non può essere osservata ma il mittente e il destinatario della comunicazione sono collegabili facilmente: non c'è anonimato!! La crittografia protegge il payload ma non protegge dall'analisi del traffico tra mittente e destinatario.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Nel caso invece di *comunicazione (cifrata) basata su un Proxy* (vedi figura sottostante) si ha che se un attaccante si posiziona sul proxy stesso, allora non c'è anonimato, altrimenti si ha che:



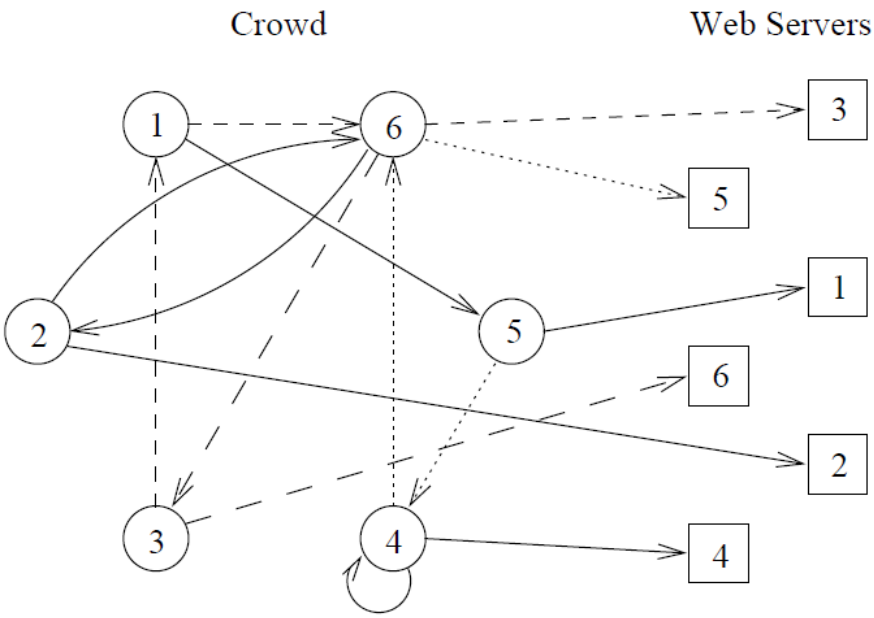
1. Prima del proxy, i mittenti sono noti ma non i destinatari
2. Dopo il proxy, i destinatari sono noti ma non i mittenti

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. Il protocollo Crowds

Crowds è un protocollo di rete orientato all'anonimato. Il concetto principale è quello di nascondere le comunicazioni di ogni utente facendole passare casualmente attraverso un gruppo di utenti simili. Né i membri di tale gruppo né il destinatario della comunicazione possono perciò essere sicuri su dove il pacchetto sia partito.

Crowds è stato progettato da Reiter e Rubin; esso protegge da attacchi interni e da un destinatario corrotto ma non fornisce anonimato contro un attaccante globale o un intercettatore locale (*local eavesdropper*). Crowds è inoltre vulnerabile al *predecessor attack*. Vediamone il funzionamento (vedi figura seguente) e le principali caratteristiche.



- Ogni utente implementa un proxy sul suo sistema
- Tale proxy è chiamato *jondo* («John Doe» nome anonimo)
- Tale *jondo* si registra presso un server (*blender)* e viene ammesso al crowd
- Ogni richiesta che parte dal sistema (browser) passa attraverso il *jondo*

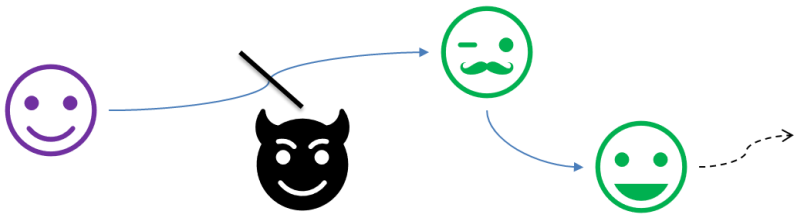
PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- Il *jondo* seleziona casualmente un altro *jondo* della rete (anche se stesso!) e inoltra a questo la richiesta.
- Quando questo *jondo* riceve la richiesta, tira una moneta (la moneta ha un bias e la probabilità di inoltro $P_f > 0.5$) per decidere se inoltrare la richiesta al destinatario finale o inoltrarla ad un altro *jondo* che procede allo stesso modo.
- La richiesta passa dal sistema mittente attraverso un certo numero di *jondo* fino al destinatario; successive richieste che cominciano dallo stesso *jondo* seguono lo stesso percorso, eccetto, eventualmente, per il server finale.
- Le risposte del server destinatario seguono lo stesso percorso al contrario.
- I collegamenti tra *jondo* sono cifrati con crittografia a chiave pubblica
- Le chiavi sono stabilite quando il *jondo* entra nel crowd.
- Un *jondo* può apparire anche più volte in un percorso

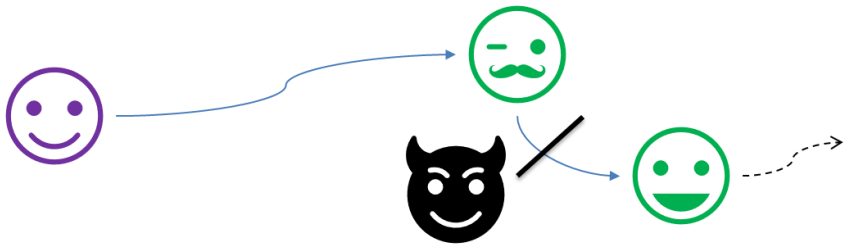
Il crowd può essere esposto all'attacco di un intercettatore locale (*local eavesdropper*), ovvero da un attaccante in grado di controllare un singolo computer (utente). Si possono avere sostanzialmente tre situazioni.

Se l'intercettatore si trova **all'uscita del computer mittente** riesce ad individuare la sorgente ma non il destinatario in quanto la comunicazione verso il *jondo* è cifrata (vedi figura qui sotto).

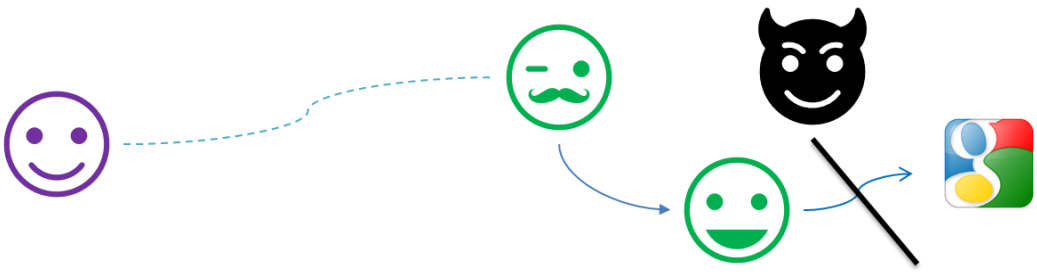


Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Nel caso in cui l'intercettatore **si trovi tra due *jondo*** allora sia il mittente che il destinatario sono anonimi: il destinatario è protetto dalla crittografia (vedi figura sottostante).

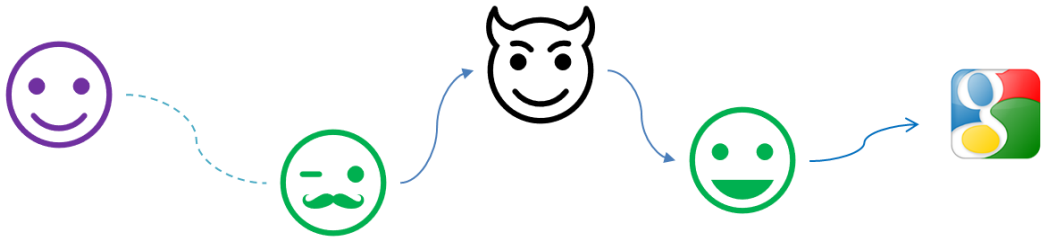


Nel caso in cui l'intercettatore **si trovi tra l'ultimo *jondo* e il destinatario**, allora il mittente è ovviamente anonimo (probabilità di 1/N, con N numero dei *jondo* nel crowd) ma il destinatario è individuabile (vedi figura qui sotto).



Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Esiste però anche il caso in cui l'attaccante, invece di inserirsi nel mezzo della comunicazione, prende possesso di uno o più *jondo* oppure si è in presenza di *jondo* «corrotti»; sicuramente, poiché ogni *jondo* può osservare in chiaro l'indirizzo del destinatario, l'anonimato del destinatario è compromesso (vedi schema nella figura sottostante).



Si può comunque anche tentare di individuare il mittente: per esempio se P_f=0,75 e se il crowd possiede N *jondo*, tale che $N \geq 3(c+1)$, allora si può dimostrare che il crowd può tollerare fino a *c jondo* corrotti. L'anonimato del mittente è quindi garantito: non si riesce a capire se «l'immediato predecessore» del *jondo* corrotto sia il mittente.

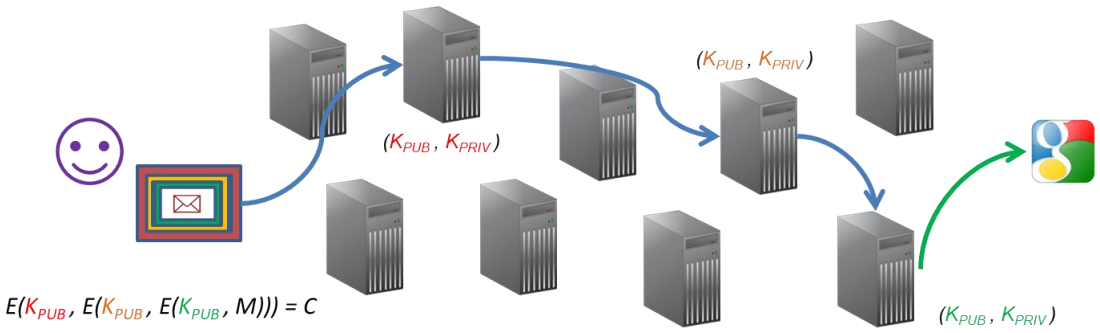
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3. Il protocollo Mix

Il protocollo **MIX** realizza una differente soluzione rispetto a Crowds per la comunicazione anonima. Progettato da David Chaum nel 1981 per le e-mail anonime è stato poi generalizzato per il traffico TCP. Esso è basato su:

- *Onion routing*
- Mixing del traffico
- Generazione di traffico "dummy"

Ogni proxy (mix) possiede una coppia di chiavi pubblica/privata (K_{PUB}/K_{PRIV}) e la comunicazione è protetta da una cifratura a strati (*onion*). Nella figura sottostante è rappresentato un esempio di funzionamento del protocollo MIX.

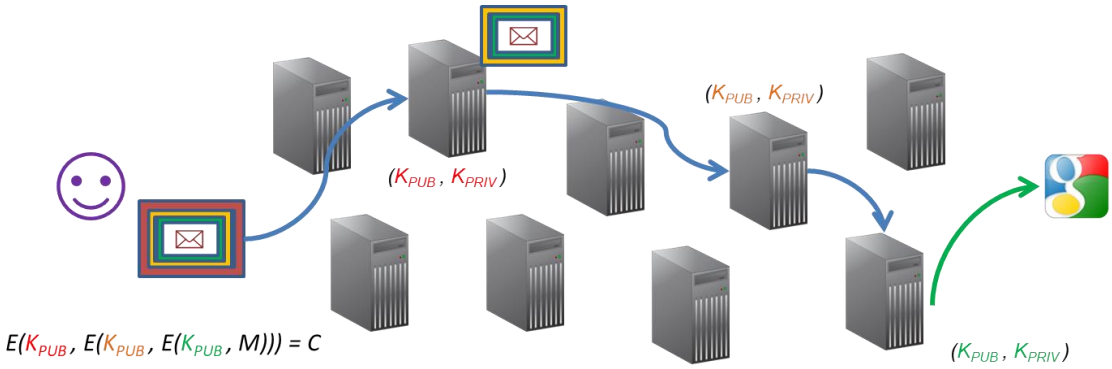


Il protocollo definisce di utilizzare un certo percorso e il mittente prepara un messaggio cifrato con le chiavi pubbliche dei proxy da attraversare; tale cifratura è effettuata in maniera annidata seguendo lo svolgimento del percorso (vedi figura qui sopra).

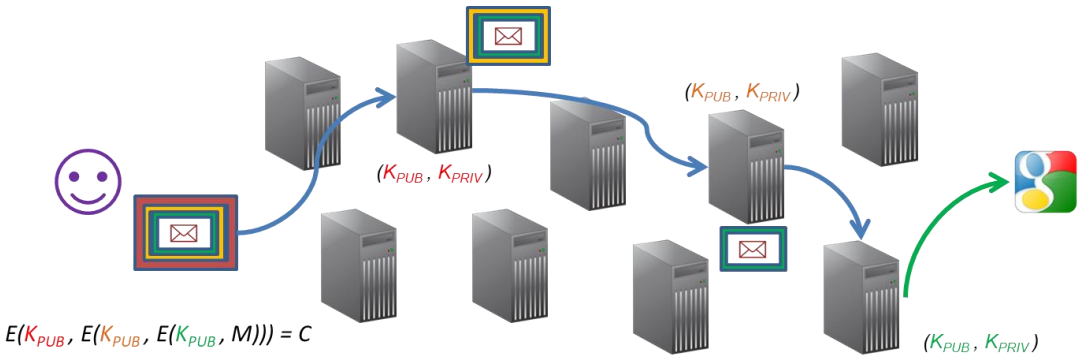
Il primo proxy effettua la decifratura dello strato più esterno con la propria chiave privata e inoltra verso il successivo proxy (vedi figura).

PEGASO
Università Telematica

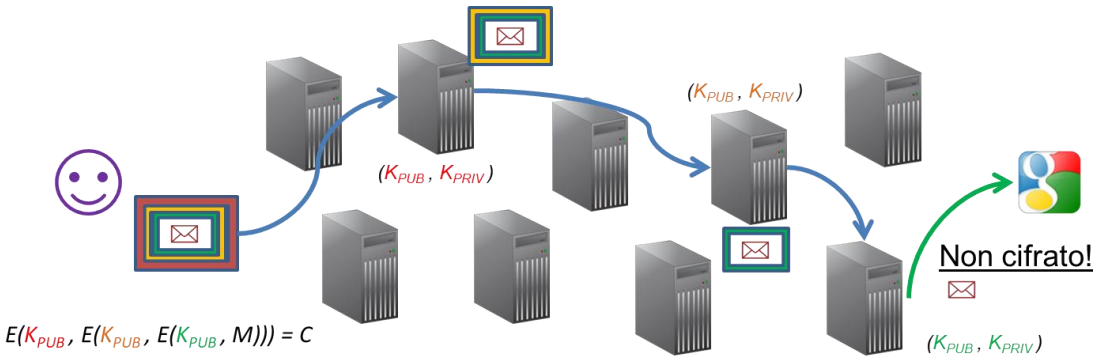
Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



In successione, i vari proxy tolgono i vari strati di cifratura e inoltrano.



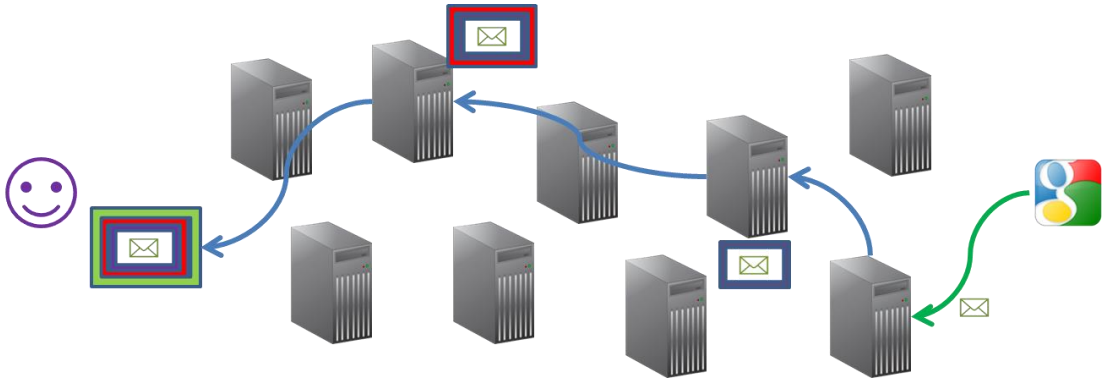
L'ultimo proxy inoltra verso il servizio finale richiesto dal mittente. Solo in questo caso si conosce il destinatario.



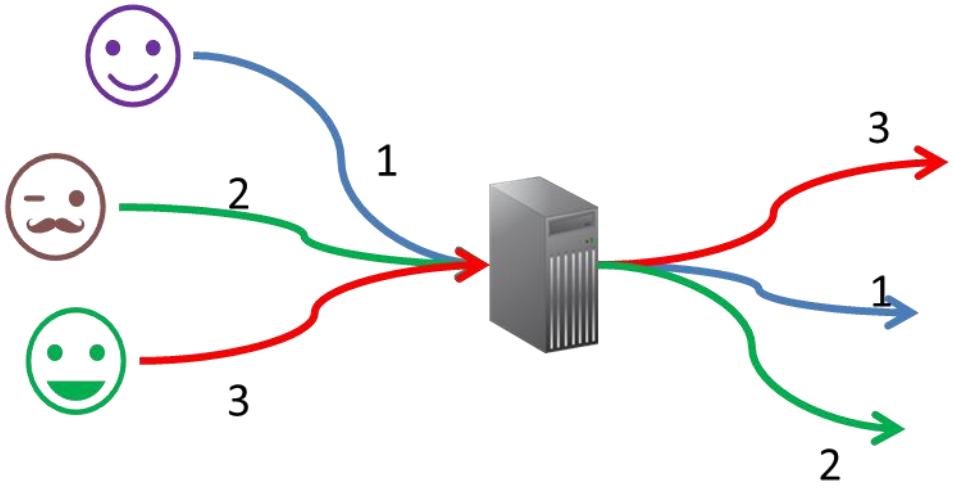
PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Il traffico di ritorno segue lo stesso percorso a ritroso. Durante l'andata il mittente rilascia su ogni proxy delle chiavi pubbliche (di cui detiene ovviamente le rispettive chiavi private) da usare per la cifratura di ritorno (vedi figura). Il mittente è così poi in grado di aprire tutte le cifrature effettuate nella fase di ritorno.



Il protocollo implementa anche un'operazione di *mixing* per garantire robustezza nei confronti del «timing attack» (nel *timing attack* si osserva la successione delle comunicazioni nel tempo). Il proxy raccoglie richieste in un certo intervallo di tempo e le inoltra in un ordine casuale diverso; può anche introdurre ritardi casuali (vedi figura successiva).

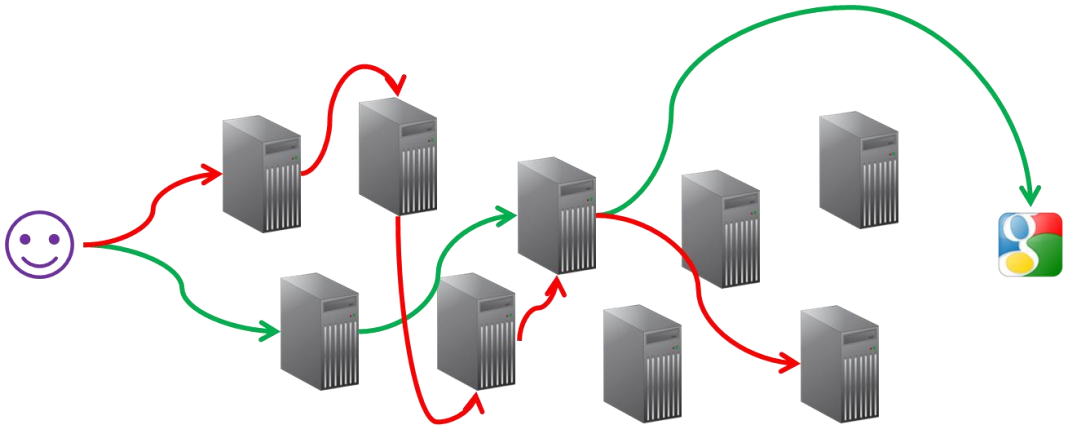


PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Gli svantaggi di questo approccio di *mixing* sono l'introduzione di una certa latenza temporale e inoltre la necessità di avere una elevata quantità di traffico per poterlo implementare in maniera efficace.

Il protocollo prevede anche la generazione di traffico «dummy» per offuscare l'invio del traffico reale (vedi esempio in figura evidenziato dal traffico "dummy" in rosso).



Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Sitografia

- CROWDS: https://www.freehaven.net/anonbib/cache/crowds:tissec.pdf
- MIX: https://www.freehaven.net/anonbib/cache/chaum-mix.pdf

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).